A3-PS011-TC116

ArgusASM

Autonomous Attack-Surface Inventory & Drift Sentinel

PS-011: Authorised attack-surface discovery and baseline-drift monitoring for a lab portfolio of domains and hosts



ZeroDayZ

· Avishkar More · Vedant Murarka

· avishkarnivasm.cy24@rvce.edu.in · vedantmurarka.cy24@rvce.edu.in

AIORI Hackathon 3 · October 14, 2026

Problem Description

Multi-cloud organizations keep accumulating exposed assets long after anyone remembers owning them.

Forgotten test subdomains

Staging and lab hosts outlive their projects and stay publicly reachable.

Expired TLS certificates

Lapsed certificates break trust and signal an unmanaged host.

Unexpected open ports

An undocumented service widens the externally reachable surface.

Dangling DNS CNAMEs

Records still point at decommissioned cloud instances: takeover candidates.

What PS-011 requires

- Authorised scope: 20 domains, 10 hosts
- 4 checks: DNS, TLS, ports, dangling DNS
- Baseline inventory with scheduled drift detection
- Immediate alerts on new services or dangling candidates
- Detect seeded issues; report false positives
- Read-only operation: no exploitation

Background

Most perimeter exposure starts as a hygiene lapse, not an attack, and it only shows if you keep a baseline.

Why the surface drifts



Multi-cloud sprawl

Resources are created and retired across providers faster than DNS and firewall records are cleaned up.



Certificates run on a calendar

Validity windows lapse silently unless expiry is tracked per host.



Test services stay listening

Temporary ports and staging hosts are rarely added to any inventory.



Baseline-driven monitoring

Snapshots track asset changes; drift detection flags unexpected services, certificate expiry and dangling DNS candidates with confidence-scored alerts.

Anatomy of a dangling CNAME

app.lab.example

CNAME

bucket-name.s3.amazonaws.com
resource deleted (NoSuchBucket)

Candidate, not proof: nobody clearly owns the target name. We flag it with a confidence level and never assume it is exploitable.

Literature & RFC Review

Standards define what to check; prior research shows how carefully a "dangling" claim must be made.

Paper, Authors & Year	Key Findings	Research Gap & ArgusASM Contribution
External Attack-Surface of Modern Organizations — Nethanel Gelernter et al. (2024)	• Studies organizational external attack surfaces. • Highlights the importance of identifying exposed assets.	• Adds unified DNS, TLS and port inventory. • Tracks baseline changes and alerts.
Cloudy with a Chance of Cyberattacks: Dangling Resources Abuse on Cloud Platforms — Jens Frieß et al. (2024)	• Identified 20,904 real-world cloud-resource hijacks. • Demonstrated the difficulty of distinguishing malicious from legitimate changes.	• Adds confidence-scored dangling DNS detection. • Combines detection with continuous drift monitoring.
Cross the Zone: Toward a Covert Domain Hijacking via Shared DNS Infrastructure — Yunyi Zhang et al. (2024)	• Identified DNS infrastructure flaws affecting 125,124 domains. • Demonstrated risks from inadequate isolation between DNS zones.	• Adds periodic DNS inventory and change detection. • Correlates DNS findings with TLS and service exposure.
All Your DNS Records Point to Us: Understanding the Security Threats of Dangling DNS Records — Daiping Liu, Shuai Hao & Haining Wang (2016)	• Found 467 exploitable dangling DNS records across 277 Alexa top-10,000 domains and 52 educational zones. • Proposed mitigation mechanisms.	• Extends dangling-record detection to a broader attack-surface workflow. • Adds baseline snapshots, alerts and a Merkle audit trail.

Proposed Solution

ArgusASM is an authorised, read-only sentinel: it inventories the perimeter, snapshots it, and alerts on drift.

Check 1: DNS inventory

A, AAAA, CNAME, MX, TXT, NS records with TTL and authoritative nameservers.

Check 2: TLS inspector

Subject, issuer, SANs, expiry. Flags expired, expiring in 14 days, mismatch.

Check 3: Ports and services

TCP connect to 22, 53, 80, 443, 8080 only. Banner read, never payloads.

Check 4: Dangling DNS

CNAME target analysis plus S3, GitHub Pages and Azure fingerprints.

Scan pipeline

1. Scope gate rejects out-of-scope targets
2. Four read-only probes run
3. Snapshot saved with Merkle root
4. Drift diff against baseline (T0)
5. Confidence-scored alert and safe fix advice

Read-only, in-scope probing

Fixed port list, no range scans

"Candidate" never means "exploitable"

Optimization Proposed

Before and after: from manual, point-in-time checks to continuous, evidence-backed monitoring.

Area	Before: manual / ad-hoc	With ArgusASM
Scope control	Targets chosen informally; risk of probing outside approval	Approved-scope file, hard caps (20 / 10); out-of-scope targets rejected before any network call
Visibility	Spreadsheets and one-off lookups	One inventory of DNS, TLS and port state per asset, with a 0 to 100 hygiene score
Change detection	Re-scan and compare by eye	Stateful snapshots (T0, T1, T2) with typed drift events and a visual diff
Alerting	Found at the next audit	Immediate alerts on new services, expired certificates and dangling candidates
Triage noise	Every hit treated as a finding	Confidence levels; wildcard DNS, CDN and staging-cert cases downgraded with reasons
Evidence integrity	Editable notes and screenshots	SHA-256 Merkle root chained across snapshots, plus a request ledger
Remediation	Left to the reader	Copy-paste advisory fixes (DNS removal, certbot, UFW); the tool never changes anything

Solution Architecture & Design

Layered design: scope gate, read-only probes, snapshot and drift engines, then alerts and dashboard.

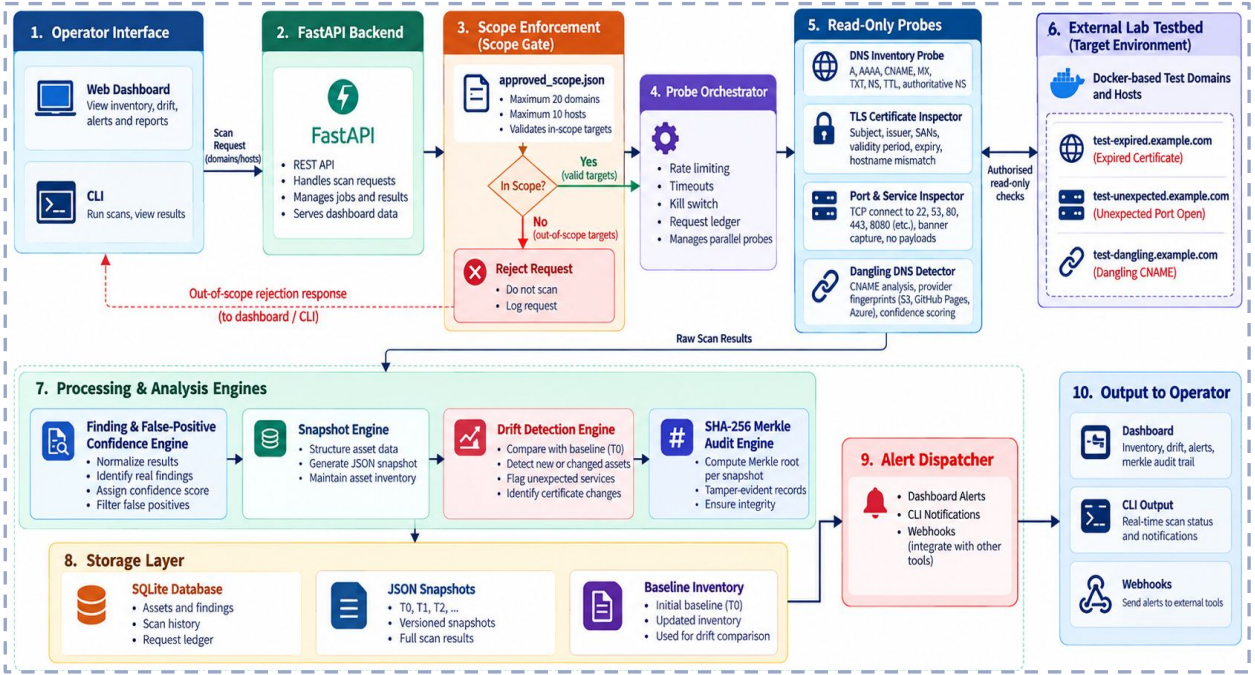


Figure: System Architecture UML Diagram

ADD HERE

UML component diagram showing

- Operator UI / CLI to FastAPI service
- Scope Enforcer with reject path
- Probe Orchestrator: rate limit, timeouts, kill switch, request ledger
- 4 probes: DNS, TLS, Ports, Dangling DNS
- FP, Snapshot, Drift and Merkle engines
- Alert dispatcher; SQLite + JSON snapshots
- Docker lab testbed as the external target

Draw in draw.io or Mermaid. Delete this note once the image is in.

Data Flow Diagram

How an authorised scan turns an approved scope into evidence, drift events and alerts.

ADD HERE

Level-0 / Level-1 DFD showing

- Entities: Operator, approved_scope.json, lab DNS and hosts
- Processes: 1 Validate scope, 2 Probe, 3 Compile and score, 4 Snapshot + Merkle, 5 Drift compare, 6 Alert
- Stores: D1 Snapshots, D2 Baseline, D3 Request ledger
- Label each flow, e.g. "approved targets", "drift events"

Reuse the flowchart made earlier. Delete this note once the image is in.

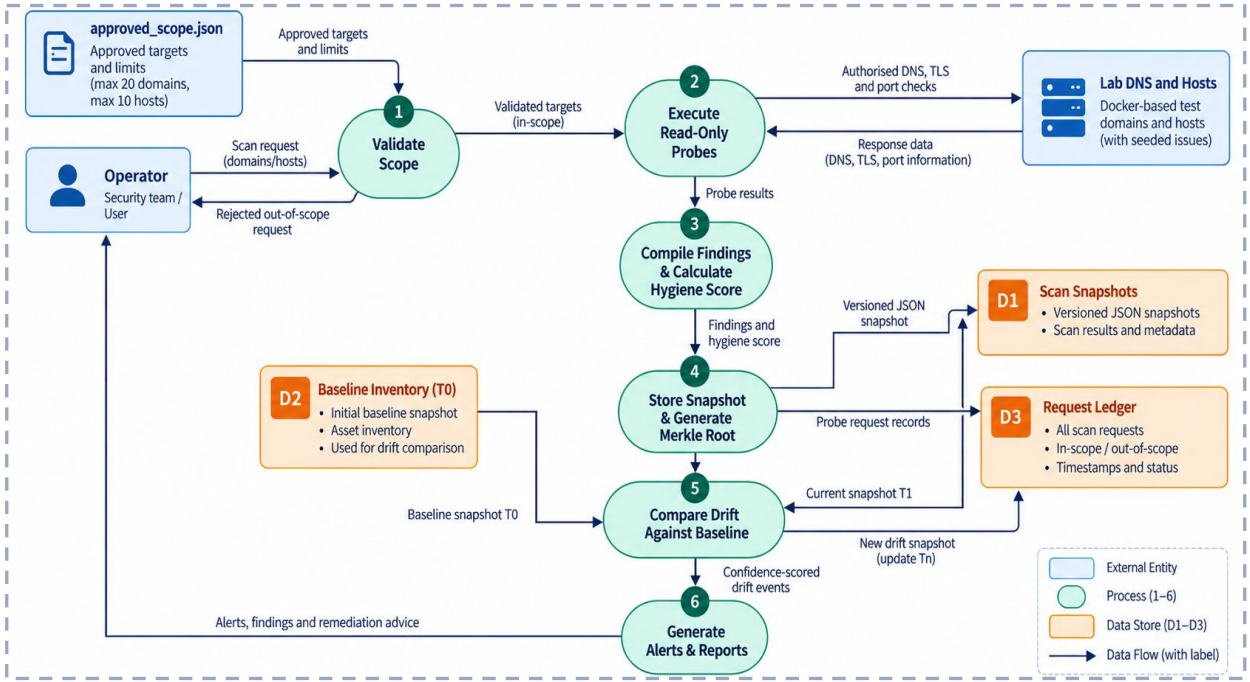
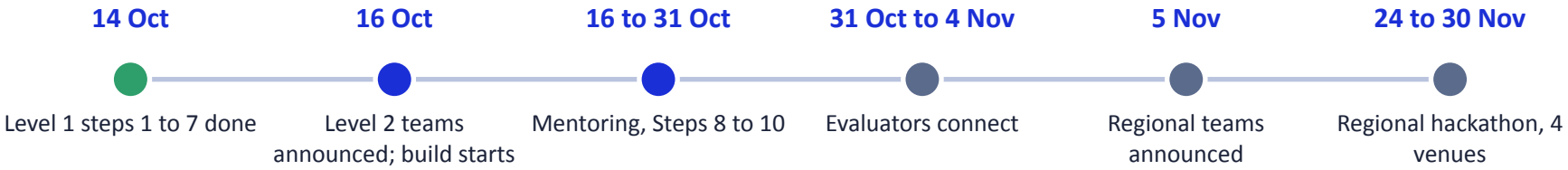


Figure: Data Flow Diagram (DFD)

Deployment Timeline

Level 2 build runs 16 to 31 Oct; submission is planned for 30 Oct, with 31 Oct kept as buffer.



Phase 1 · 16 to 19 Oct

Foundation and 4 probes

Scope gate, DNS, TLS, port and dangling probes, one-click scan.

Phase 2 · 20 to 23 Oct

Drift engine and lab

Snapshots, diff viewer, Docker testbed with 3 seeded issues.

Phase 3 · 24 to 27 Oct

Differentiators

Asset graph, FP engine, time-travel slider, remediation, Merkle chain.

Phase 4 · 28 to 30 Oct

Docs and submission

Proposed-structure PDF, live demo, 3-min video; 31 Oct freeze.

Deployment: docker compose up for lab and app; CI runs pytest and the seeded validation on every push; live demo on one VM (lab scope only), with a recorded demo and sample snapshots as fallback.

Bibliography

[1] P. Mockapetris, “Domain names—Implementation and specification,” RFC 1035, Internet Engineering Task Force (IETF), Nov. 1987.

[2] D. Cooper *et al.*, “Internet X.509 public key infrastructure certificate and certificate revocation list (CRL) profile,” RFC 5280, IETF, May 2008.

[3] P. Saint-Andre and R. Salz, “Service identity in TLS,” RFC 9525, IETF, Nov. 2023.

[4] R. Fielding, M. Nottingham, and J. Reschke, Eds., “HTTP semantics,” RFC 9110, IETF, Jun. 2022.

[5] B. Laurie, A. Langley, and E. Kasper, “Certificate transparency,” RFC 6962, IETF, Jun. 2013.

[6] D. Liu, S. Hao, and H. Wang, “All your DNS records point to us: Understanding the security threats of dangling DNS records,” in *Proc. ACM SIGSAC Conf. Comput. Commun. Secur. (CCS)*, 2016, pp. 1414–1425, doi: 10.1145/2976749.2978387.

[7] OWASP Foundation, “Test for subdomain takeover (WSTG-CONF-10),” *OWASP Web Security Testing Guide*. [Online]. Available: https://owasp.org/www-project-web-security-testing-guide/

[8] EdOverflow *et al.*, “Can I take over XYZ?—Subdomain takeover fingerprints,” GitHub repository. [Online]. Available: https://github.com/EdOverflow/can-i-take-over-xyz

[9] R. C. Merkle, “A digital signature based on a conventional encryption function,” in *Advances in Cryptology—CRYPTO ’87*, Lecture Notes in Computer Science, vol. 293. Berlin, Germany: Springer, 1988, pp. 369–378.

[10] C. Evans, C. Palmer, and R. Sleevi, “Public Key Pinning Extension for HTTP,” RFC 7469, IETF, Apr. 2015. [Online]. Available: https://www.rfc-editor.org/rfc/rfc7469

Thank You for Your Attention!

ArgusASM: continuous visibility, zero exploitation.



ZeroDayZ · A3-PS011-TC116

· GitHub: repository link